PRUEBA DE PENETRACIÓN - SPIKA TECH

INFORMACIÓN GENERAL

Nombre del Proyecto: Evaluación de Seguridad Integral Spika Tech

Fecha programada: 27/07/2025

Tipo de prueba: Revisión de arreglos

Autorizado por: Jaime de Castro

1. ALCANCE Y OBJETIVOS

1.1 Alcance

- Sitio web corporativo y aplicaciones web

1.2 Objetivos

- Identificar vulnerabilidades en la infraestructura tecnológica
- Evaluar la eficacia de los controles de seguridad existentes
- Verificar el cumplimiento con ISO 27001
- Determinar posibles vectores de ataque que puedan comprometer datos sensibles
- Proporcionar recomendaciones accionables para la remediación

2. METODOLOGÍA Y HERRAMIENTAS

2.1 Marcos de Referencia

- OWASP Testing Guide para aplicaciones web
- Cloud Security Alliance para entornos Firebase/Google Cloud
- NIST SP 800-115 para procedimientos generales

2.2 Herramientas a utilizar

- Seguridad Web: OWASP ZAP(ZAProxy)

3. PLAN DE PRUEBAS DETALLADO

3.1 Fase de Preparación

- Notificado personal relevante: jefe de ciberseguridad y administrador de sistemas
- Dimensionamiento de la infraestructura digital de Spika Tech: estudio de dominios y endpoints
- Obtención de cuenta de google Cloud con capacidad de lectura
- Cuenta de OVH pendiente

3.2 Pruebas del Sitio Web

- Escaneo automatizado con OWASP ZAP
- Verificación de gestión de sesiones y autenticación
- Análisis de configuración de seguridad

4. Hallazgos y vulnerabilidades

Escaneo de dominios pertinentes asociados a *.spikatech.com:

Subdominio	IP
spikatech.com	37.59.203.111
www.spikatech.com	37.59.203.111
compasstest.spikatech.com	37.59.203.111
memoria-2017.spikatech.com	37.59.203.111
mqtt.spikatech.com	37.59.203.111
www.mqtt.spikatech.com	37.59.203.111
itserver.spikatech.com	193.147.50.21
visualcardiopipeline.spikatech.com	34.32.227.118
visualcardiopipelineprod.spikatech.com	34.107.152.59
itilapplication.spikatech.com	87.98.231.18
www.itilapplication.spikatech.com	87.98.231.18

spikatech.com

OWASP ZAP (Informe generado en ANEXO I)

Vulnerability	Severity
Vulnerable JS Library: pdf.js 2.5.207	Medium
Absence of Anti-CSRF Tokens	Medium
Secure Pages Include Mixed Content (Including Scripts)	Medium
Missing Anti-clickjacking Header	Low
Content Security Policy (CSP) Header Not Set	Low
X-Content-Type-Options Header Missing	Low